# Pentesting - Offensive:
# Red Team, Pentester & Researcher

Taller de Seguridad

Ing. Martin Di Paola - Fiuba

Threat Model well thought.
Mechanisms and policies are in-place, in each sec interface.

Now...

- Are **correctly** configured?
- Did I **forget** something?
- On an attack, would I **block** it?
    - Would I **notice** it?
    - Would I know how to react?

All the defences are perfect until they are tested for real.

Penetration test (aka pentest)

Red Team

Pentester

Researcher

Red Team

Pentester

Researcher

Social

Physical

Front / Backend

Multi-disciplines

A chain is only as strong as its weakest link

Red Team

Pentester

Researcher

Physical

Social

Front / Backend

Multi-disciplines

A chain is only as strong as its weakest link

Red Team

Pentester

Researcher

Physical

Social

Front / Backend

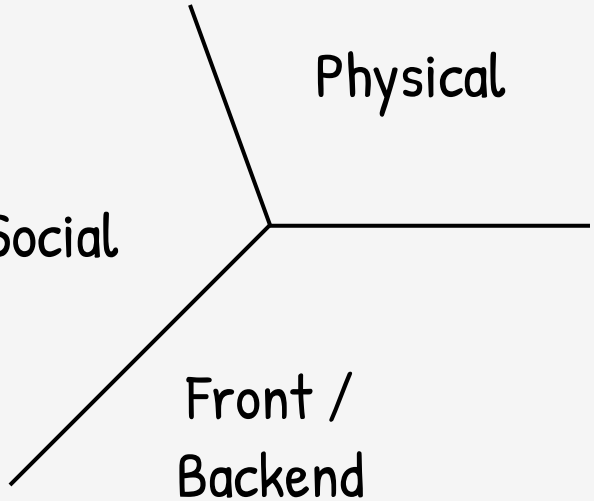
Multi-disciplines

A chain is only as strong as its weakest link

*Goal*

Simulate real attacks

Specialization




Red Team

Pentester

Researcher

Hardware Pentester

Intrusion Pentester

.....

Social Eng.
Pentester

.....

Specialization

Red Team

Web Pentester

Android Pentester

.....

Pentester

Researcher

Hardware Pentester

Intrusion Pentester

.....

Social Eng.
Pentester

.....

Specialization

Red Team

Web Pentester

Android Pentester

.....

Pentester

*Goal*

Find
Vulnerabilities

Researcher

Red Team

Pentester

Researcher

Exploit Writting

Reversing Eng.

Cryptography

Malware Analysis

Windows Kernel

Android Kernel

Xen Hypervisor

BIOS

Hardware

Signing Scheme

Chain Analysis

Antivirus Detection

Sandbox

Red Team

Pentester

Researcher

*Goal*

Develop ***new*** vulns & techniques

Exploit Writting

Reversing Eng.

Cryptography

Malware Analysis

Windows Kernel

Android Kernel

Xen Hypervisor

BIOS

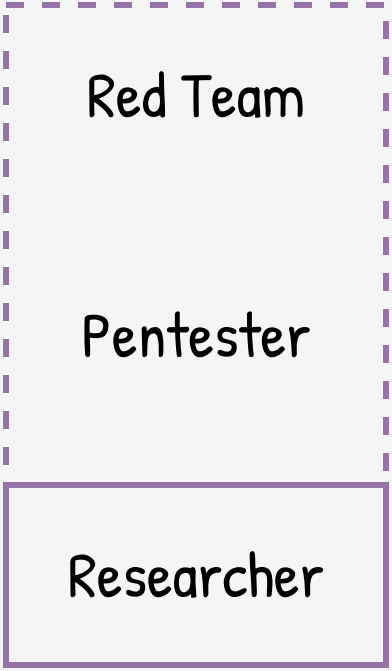
Hardware

Signing Scheme

Chain Analysis

Antivirus Detection

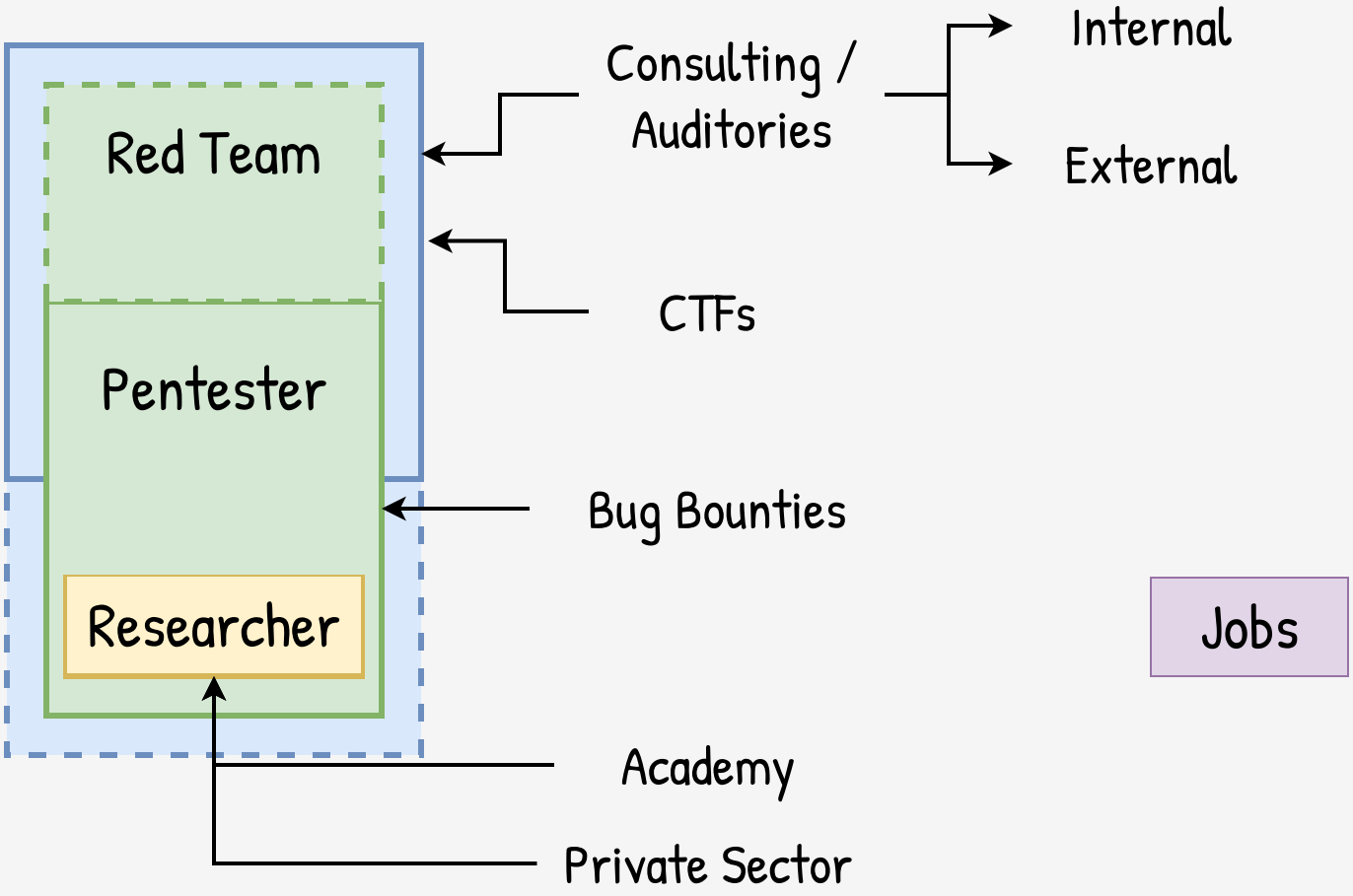
Sandbox




## Disclosure

(but **check** with legals)

- Share findings
- Coordinate schedule for fix, revalidation and disclosure
- 90 days deadline for full disclosure
- It shouldn't be necessary but sometimes you need to ***"hide"*** yourself


Red Team
Pentester
Researcher
Consulting / Auditories
Internal
External
CTFs
Bug Bounties
Jobs
Academy
Private Sector

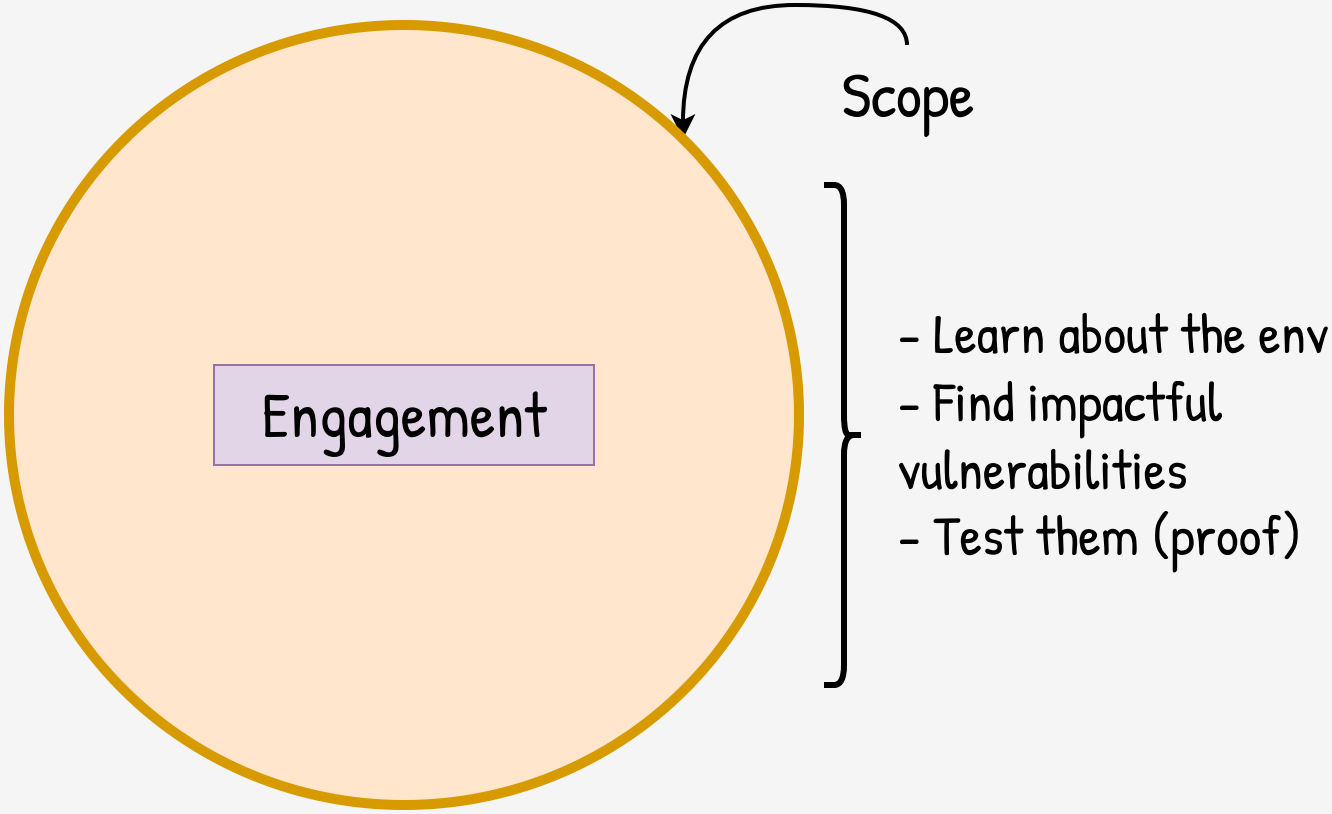
- What should we focus on?
- What is and isn't allowed?
- What initial info do we have?
- What is the timeframe? Any schedule restriction?
- What is the legal framework?

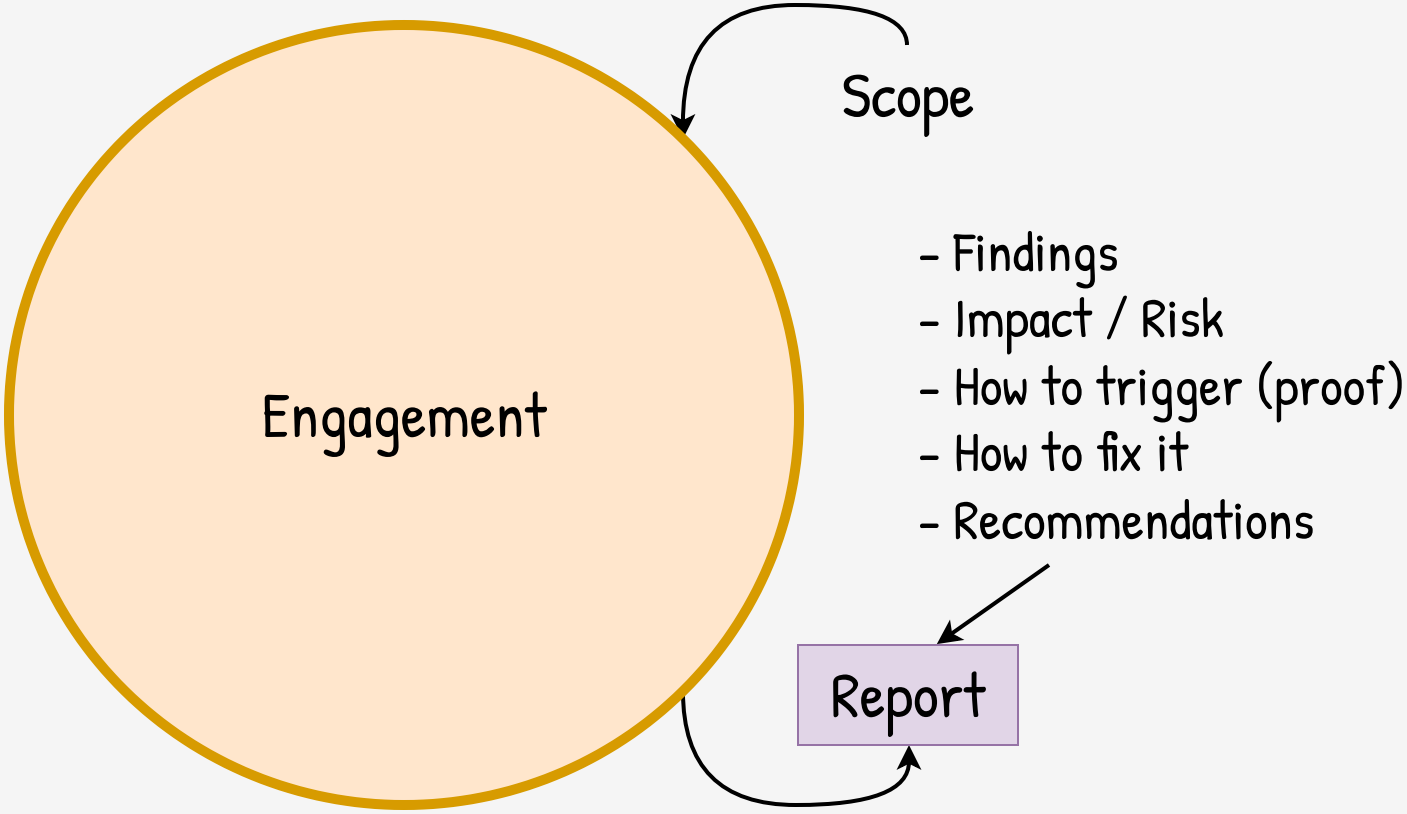
Scope

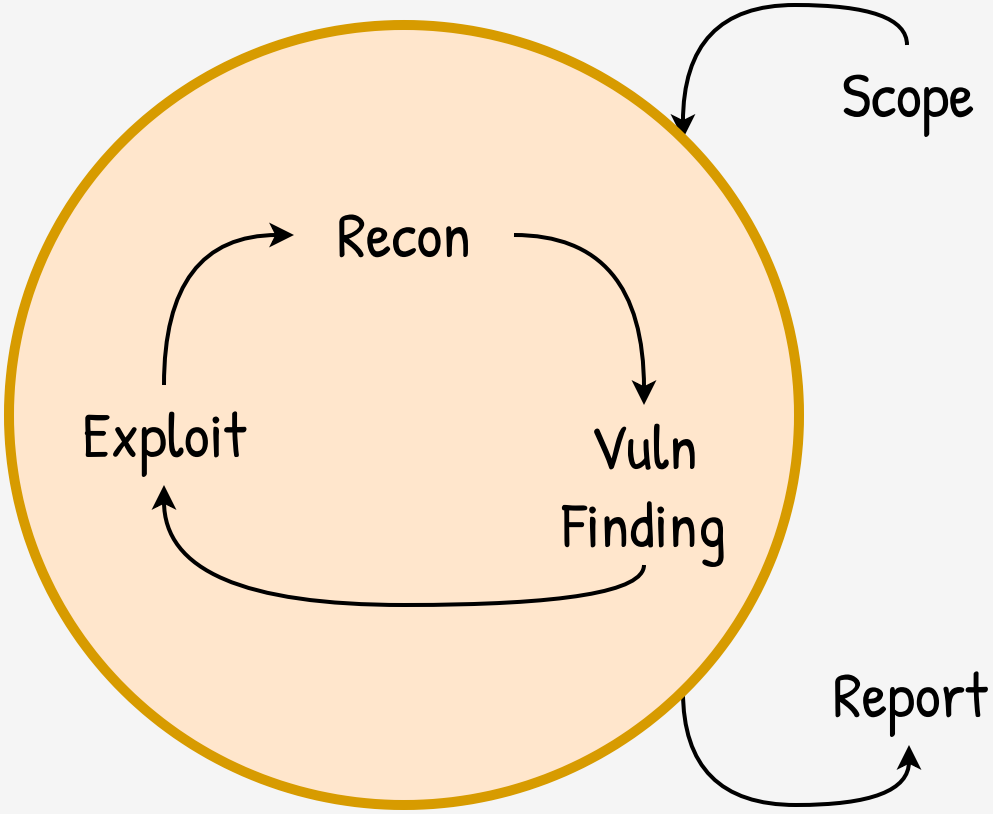
Client

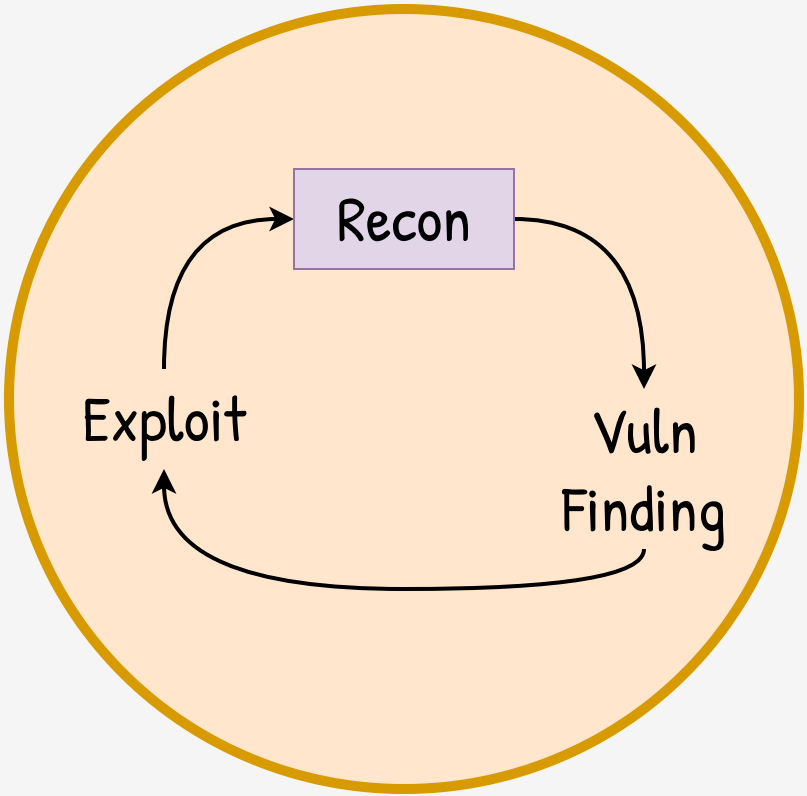
Written Contract

Red Team / Pentester


Scope
Engagement
- Learn about the env
- Find impactful vulnerabilities
- Test them (proof)

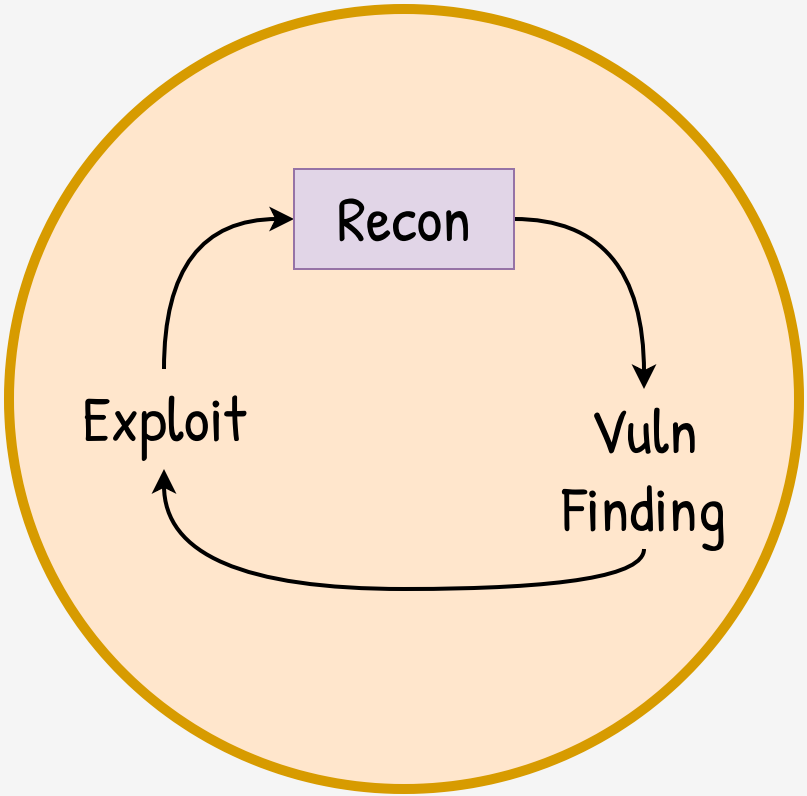

Scope
Engagement
- Findings
- Impact / Risk
- How to trigger (proof)
- How to fix it
- Recommendations
Report


Scope
Recon
Exploit
Vuln
Finding
Report




Reconnaissance /
Information Gathering

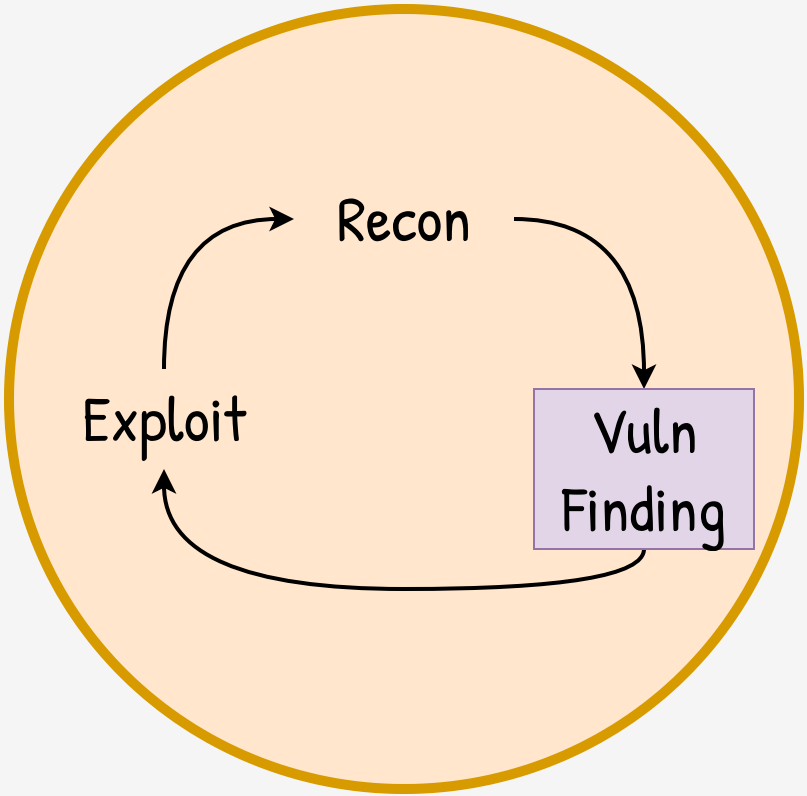
- Hosts, ports, fw rules, DNS
- Processes, users, services, permissions, prog versions
- People names, emails, roles




Reconnaissance /
Information Gathering

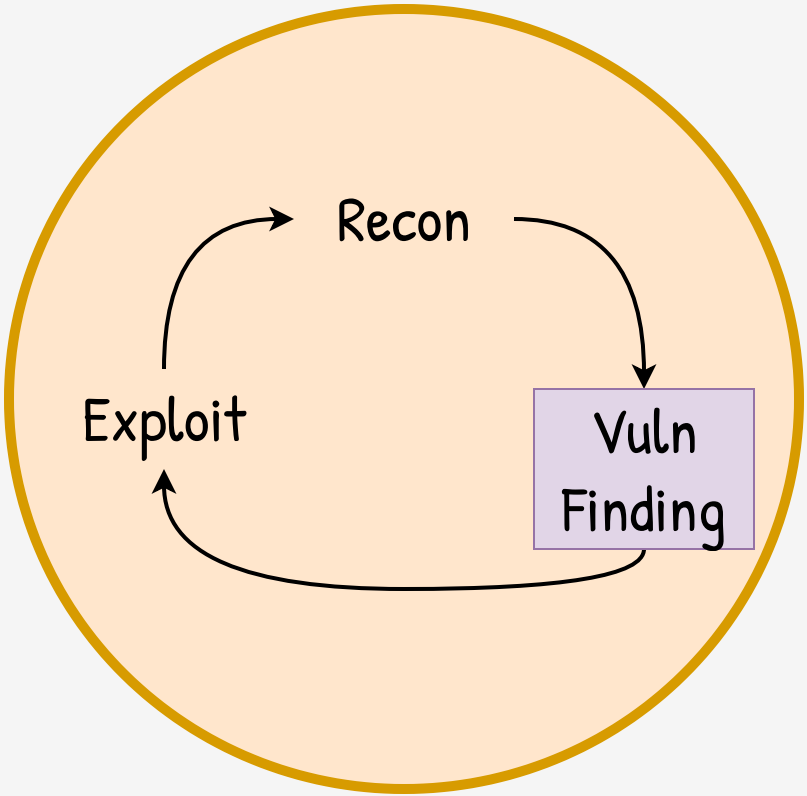
- Hosts, ports, fw rules, DNS
- Processes, users, services, permissions, prog versions
- People names, emails, roles

Learn, visibility and plan the next step




Vulnerability
Finding

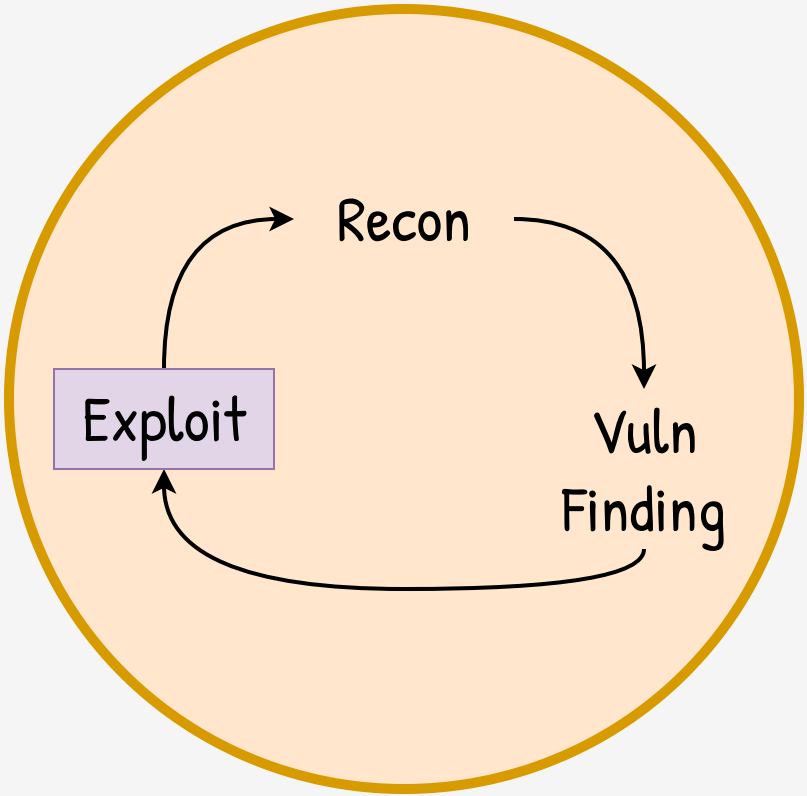
- What can we read/write/exec and we should't?
- Info leak, priv escalation, ...
- Proof of their existence




Vulnerability Finding

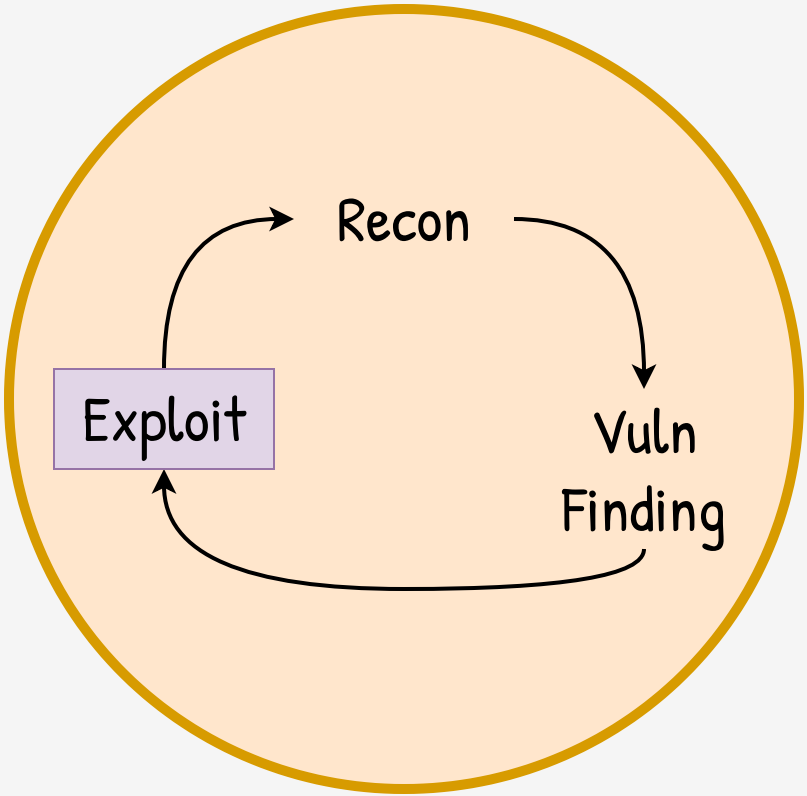
- What can we read/write/exec and we should't?
- Info leak, priv escalation, ...
- Proof of their existence

Find vulns relevant to our client and/or to our engagement




Exploit a Vulnerability

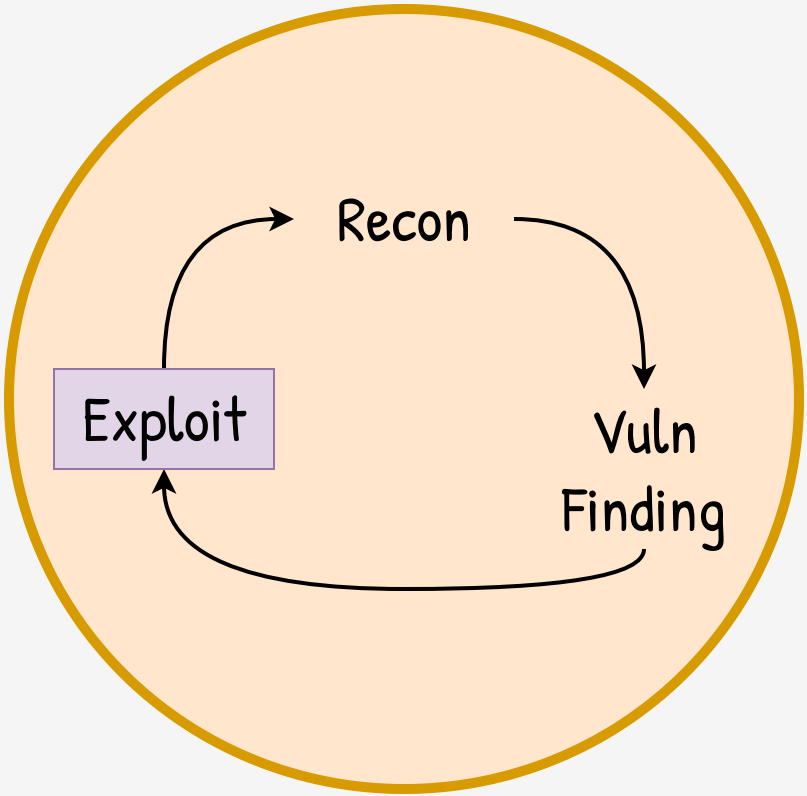
- Take advantage of a vuln to actually read/write/exec
- Do not cross scope or legals




Exploit a Vulnerability

- Take advantage of a vuln to actually read/write/exec
- Do not cross scope or legals

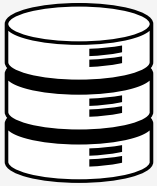
- Priviledge escalation
- Lateral movement
- See further
- Get the cookie



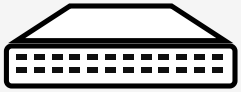

Exploit a Vulnerability

- Take advantage of a vuln to actually read/write/exec
- Do not cross scope or legals

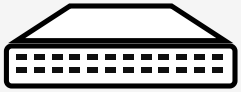
Enable **more** recon & vuln finding



prod DB



pub.47



pub.48

Company's
internal network

**Scope:**

- scan is OK
  - IPs: pub.47 pub.48
- use creds OK
  - but no creds given
- social eng **NOT** ok
- use exploits on prod **NOT** ok
- no more info (blackbox)

**Goal:**

- ~~exfiltrate prod DB~~
  - that's **NOT** for legals (us),
  - better: **prove** that prod DB can be exfiltrated

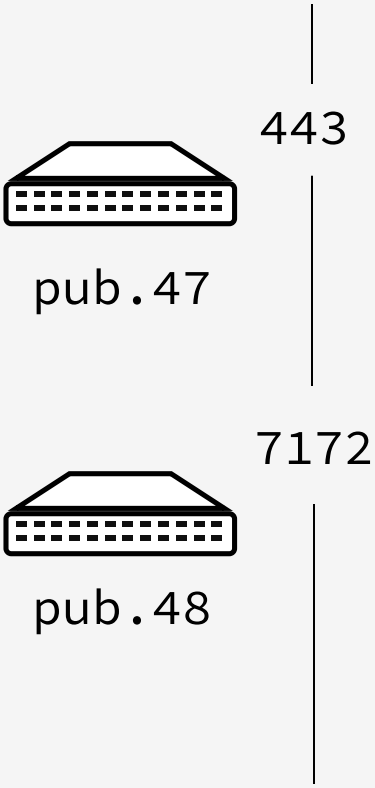
# What's next?

pub.47

pub.48

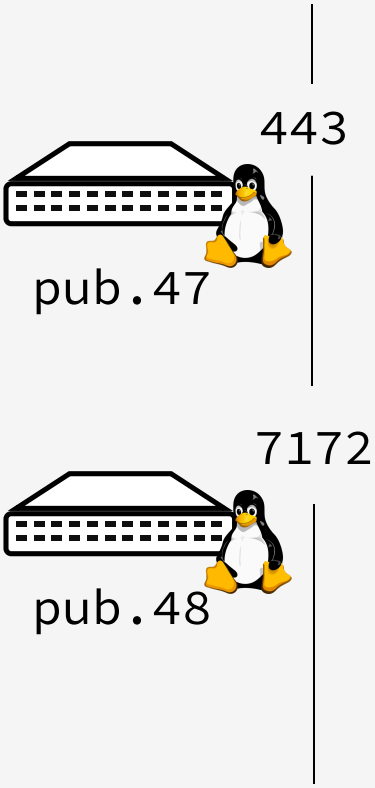
Recon

```
nmap pub.47
nmap pub.48
```



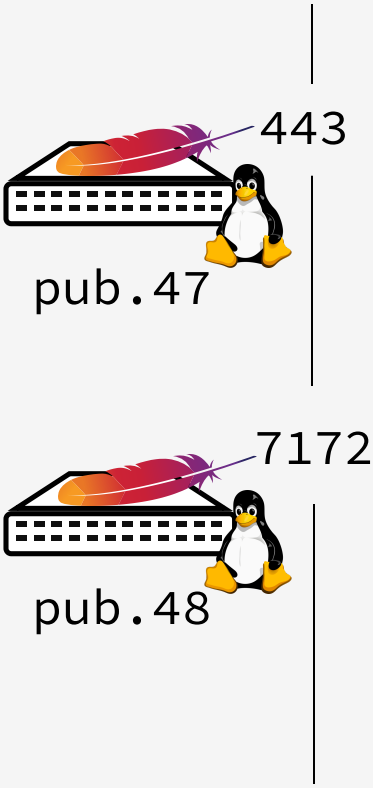
Recon

```
nmap pub.47
nmap pub.48
```

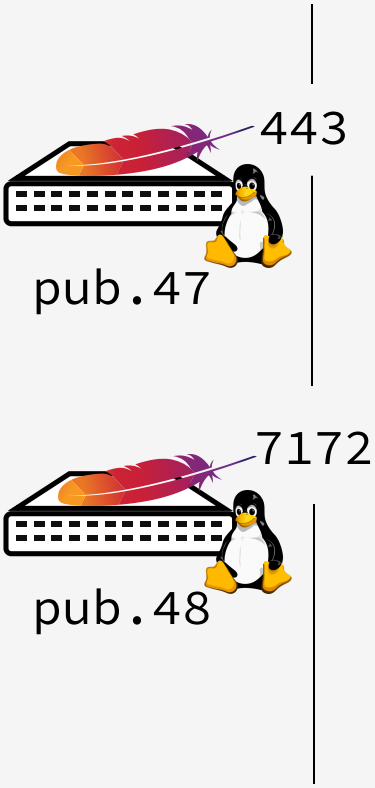


Recon

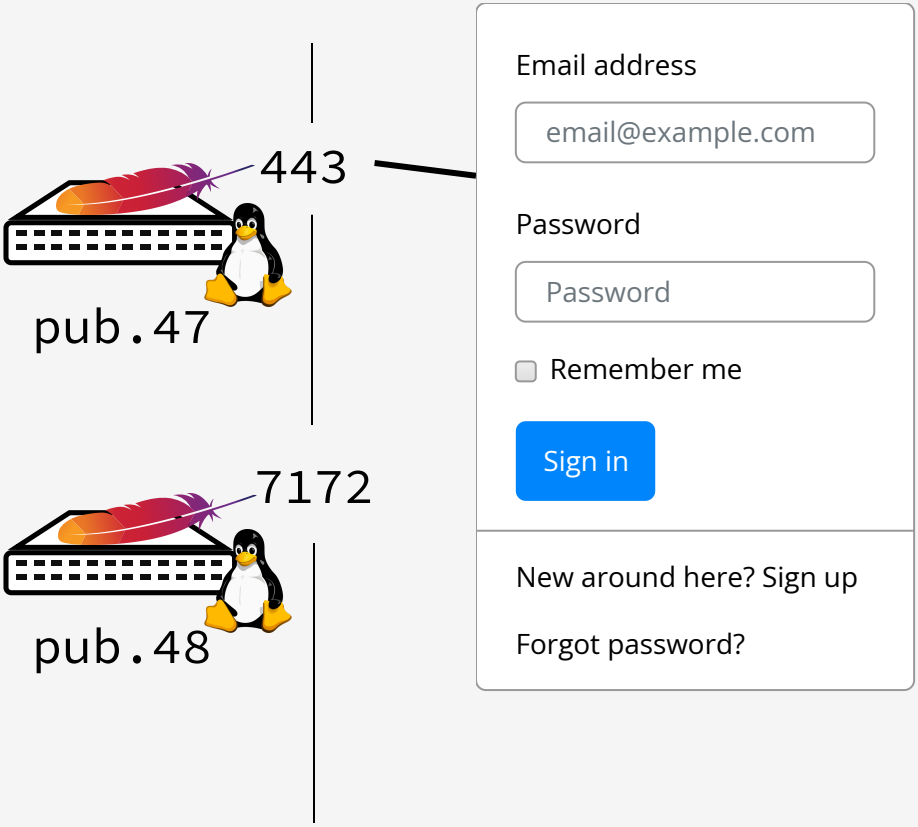
```
nmap pub.47
nmap pub.48
```



# What's next?



# Recon


443
pub.47
7172
pub.48
Email address
email@example.com
Password
Password
Remember me
Sign in
New around here? Sign up
Forgot password?

Recon

emails:
- from social networks
- from public websites
- from default lists

443

pub.47

7172

pub.48

Email address

email@example.com

Password

Password

Remember me

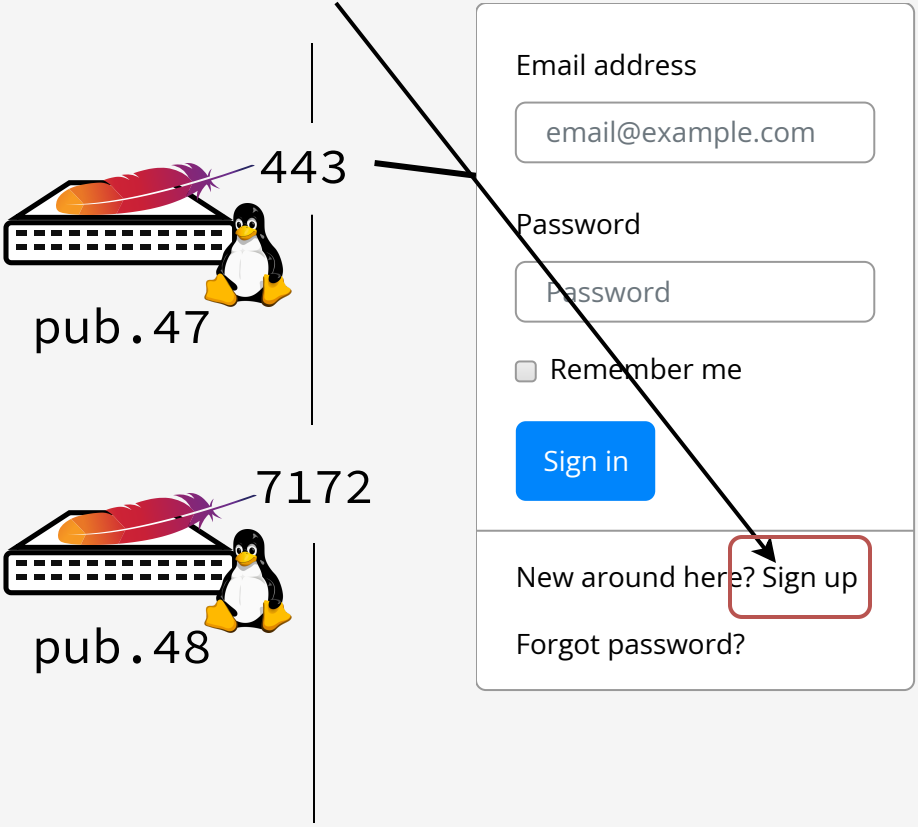
Sign in

New around here? Sign up

Forgot password?

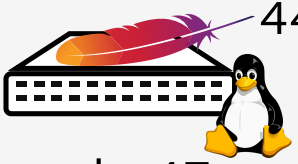
Recon

create account?
- it asks for a registration code that we don't have



Recon

X password recovery?
- it looks solid



443

pub.47

7172

pub.48

Email address

email@example.com

Password

Password

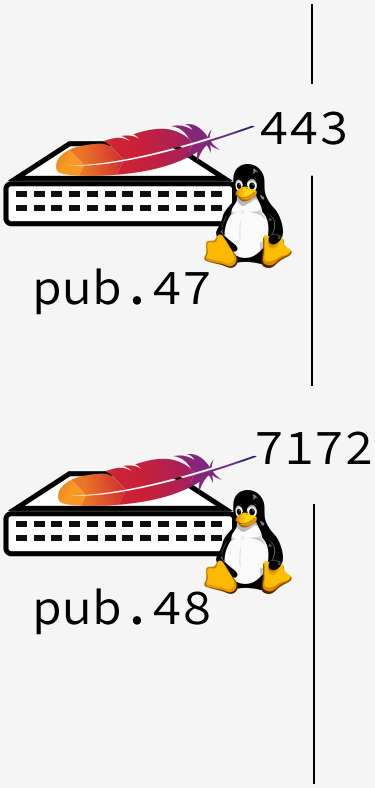
Remember me

Sign in

New around here? Sign up

Forgot password?

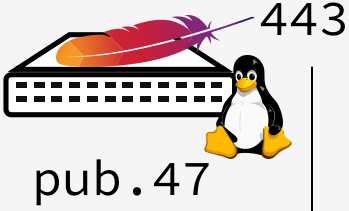
# What's next?

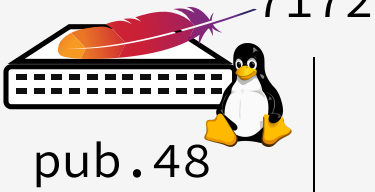


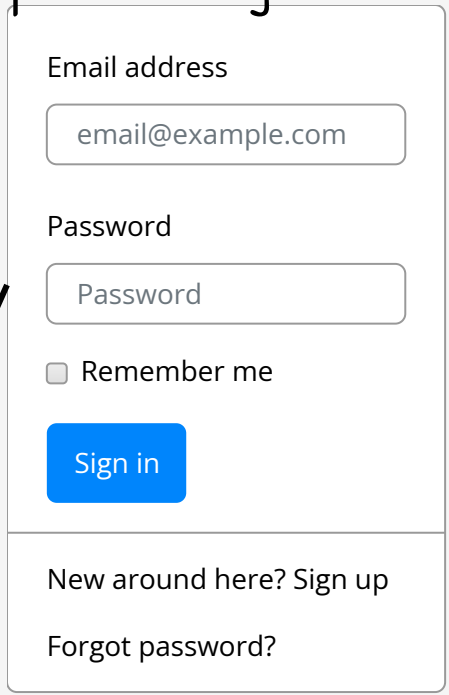
Recon

emails:
- from social networks
- from public websites
- from default lists

email: test@test.com
pass: testing



Find Vuln

? `john' or 1=1`

? `john" or 1=1`

✓ `john' || pg_sleep(1) --`

???

Find Vuln

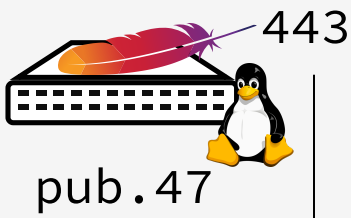
? `john' or 1=1`

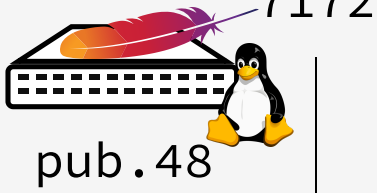
? `john" or 1=1`

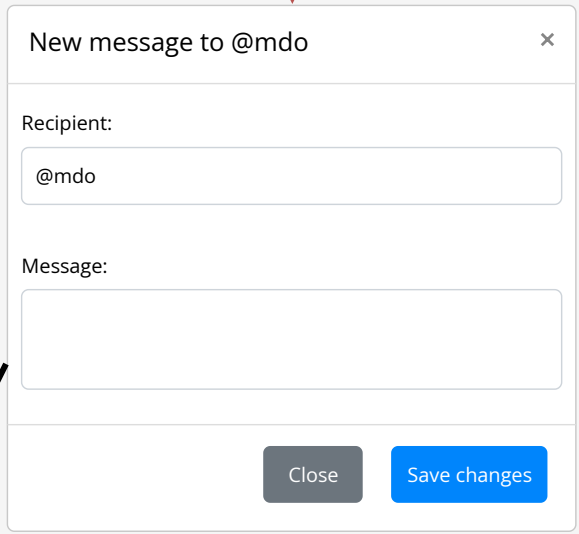
✓ `john' || pg_sleep(1) --`

sqli

(blind)





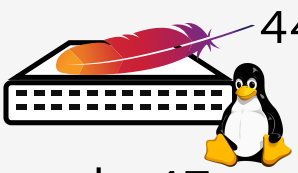



Recon

SQL injections to learn about the DB and environment

sqli

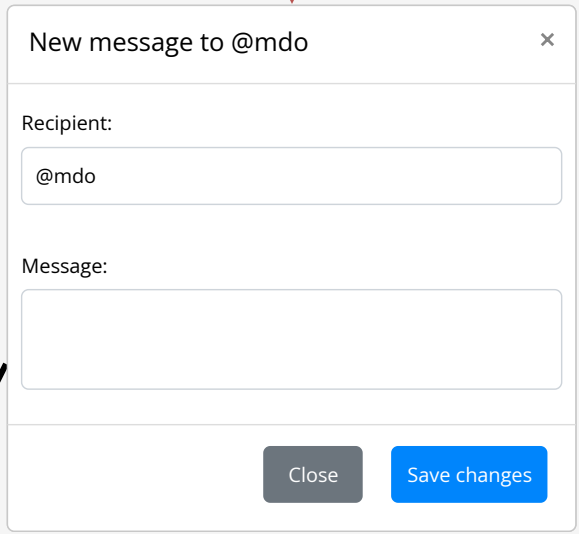
(blind)




pub.47

pub.48

postgres
ver 12.1
superuser

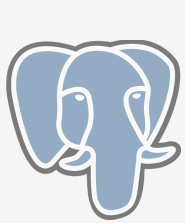


Recon

SQL injections to learn about the DB and environment

sqli

(blind)



?

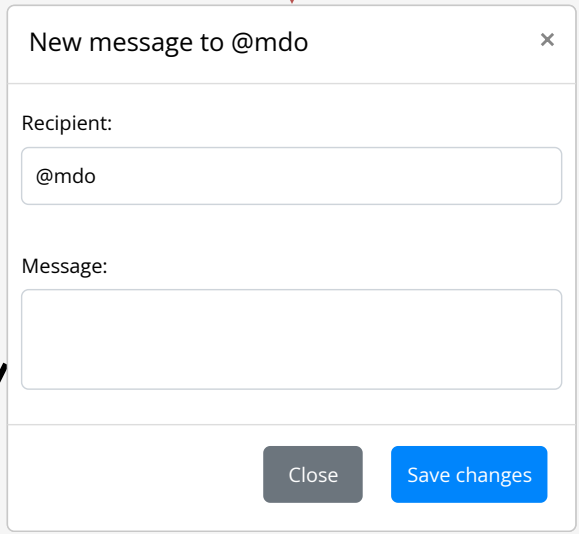
443

pub.47

7172

pub.48

postgres
ver 12.1
superuser

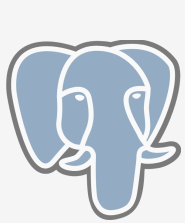


SQL injections to learn about the DB and environment

sqli

(blind)

What's next?



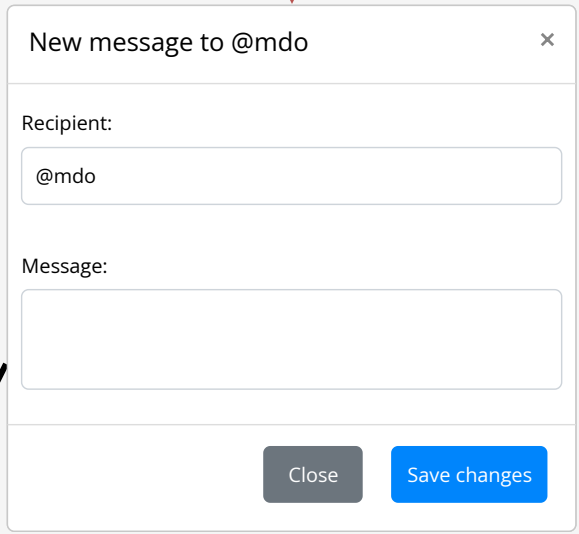
443

pub.47

7172

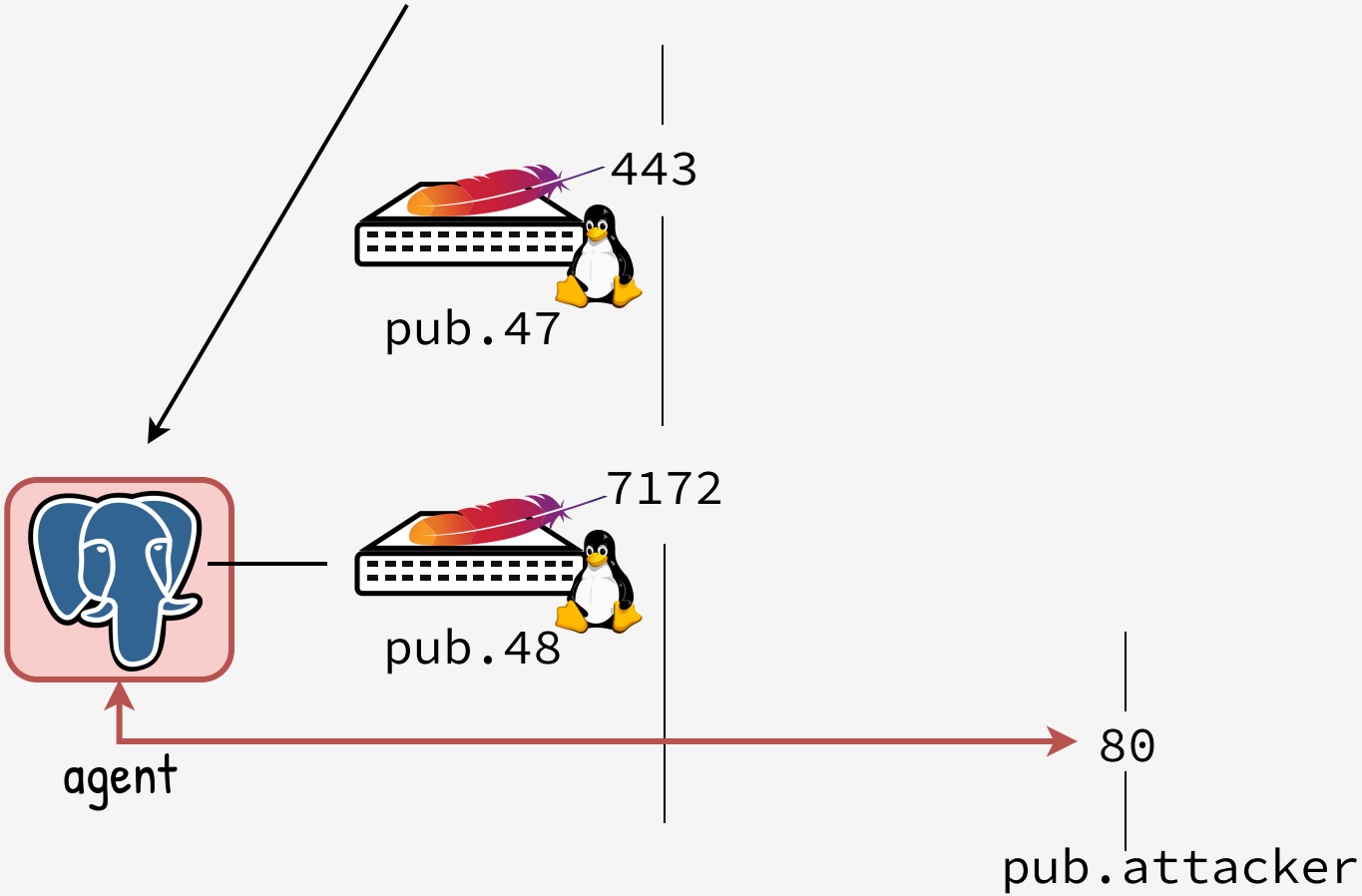
pub.48

postgres
ver 12.1
superuser



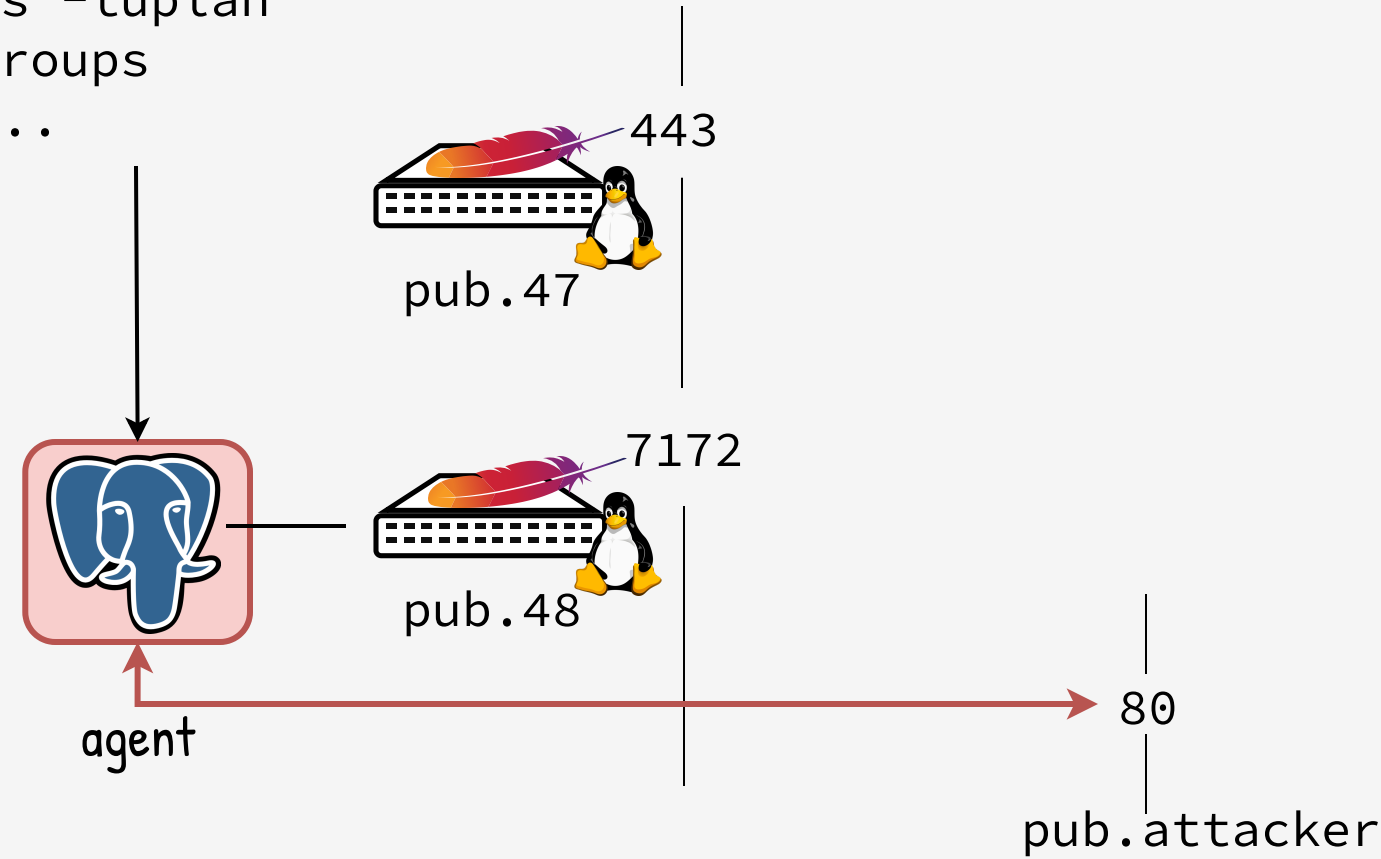
Exploit

```
COPY (SELECT '')
TO PROGRAM '...shellcode...';
```

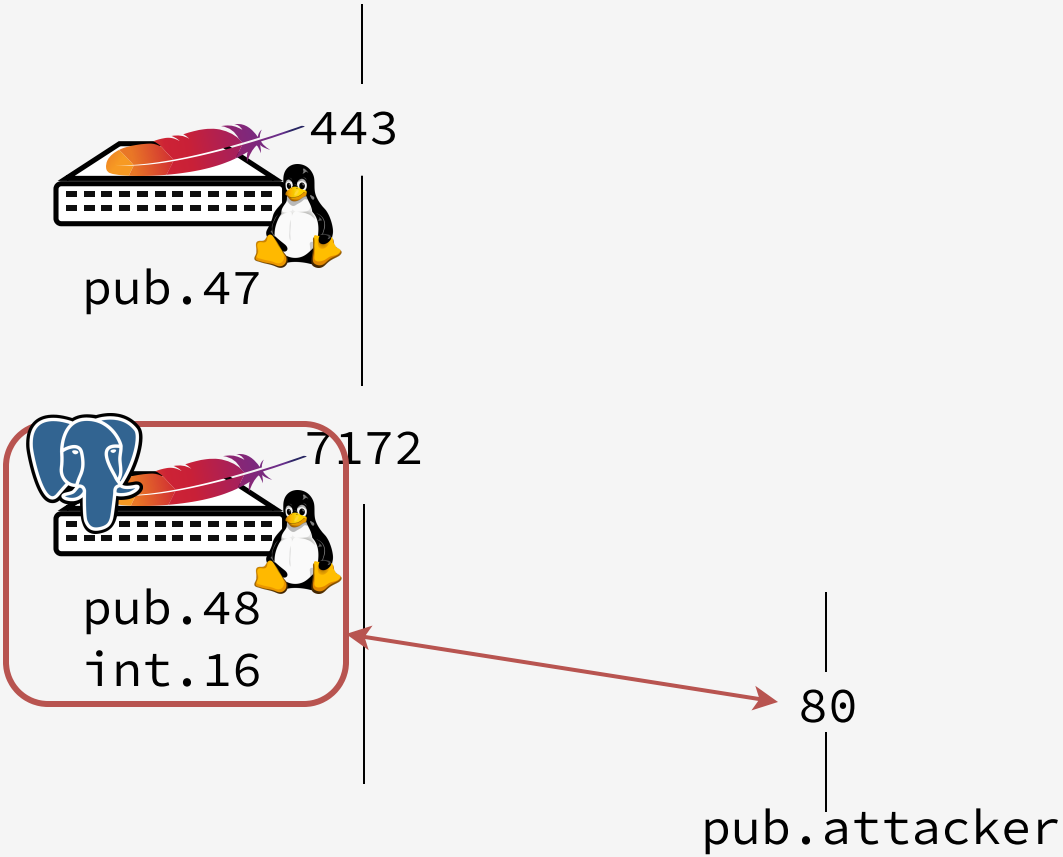


Recon

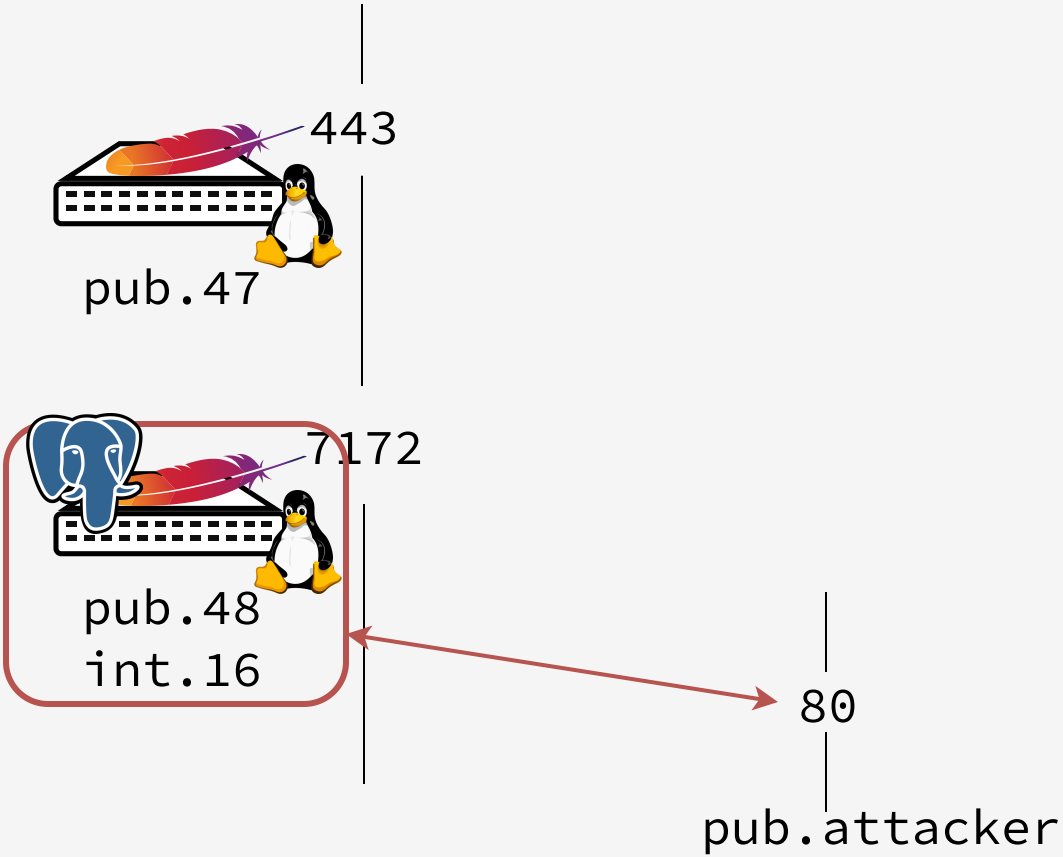
```
ps aux
ip addr
ss -tuplan
groups
...
```



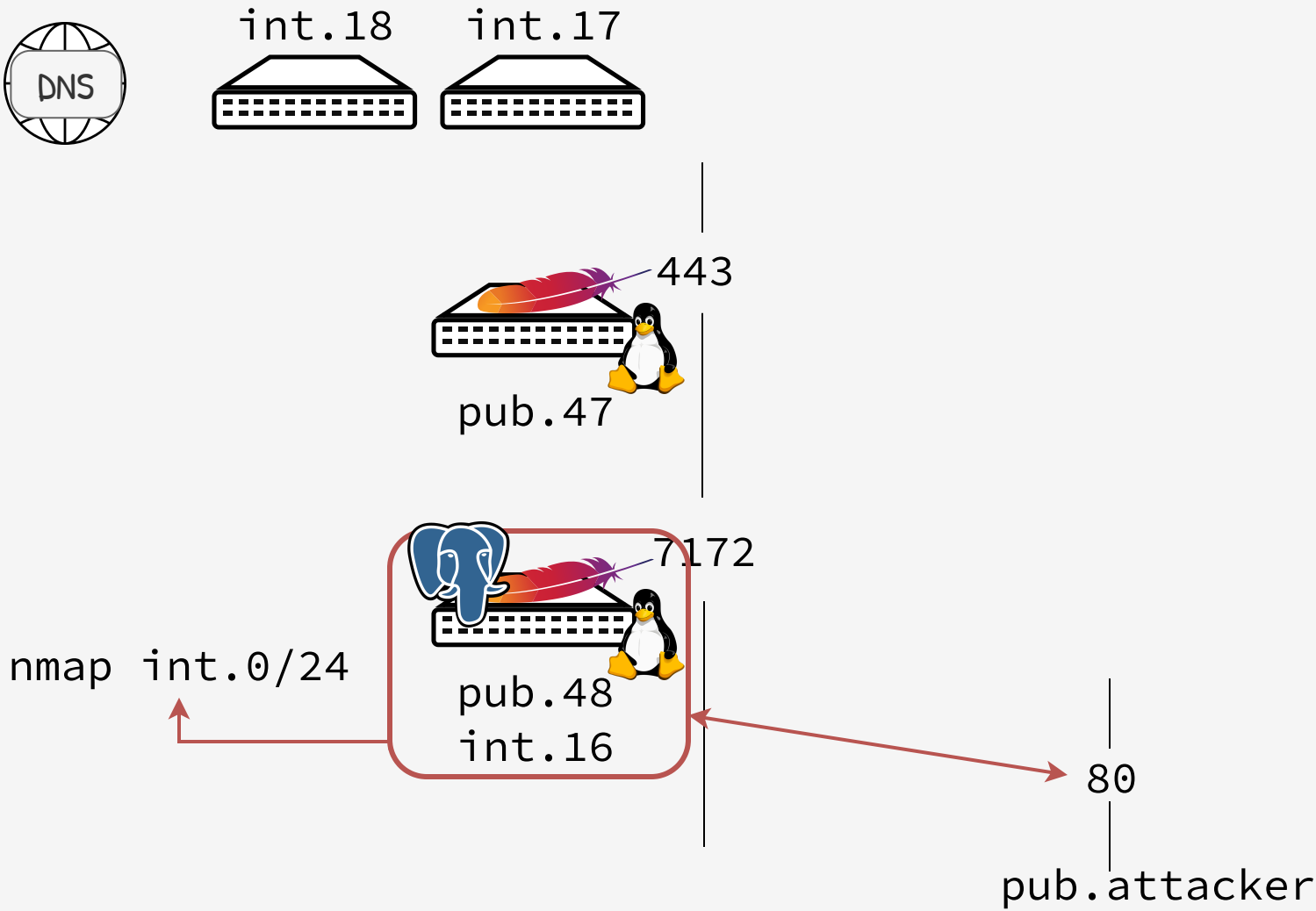
Recon

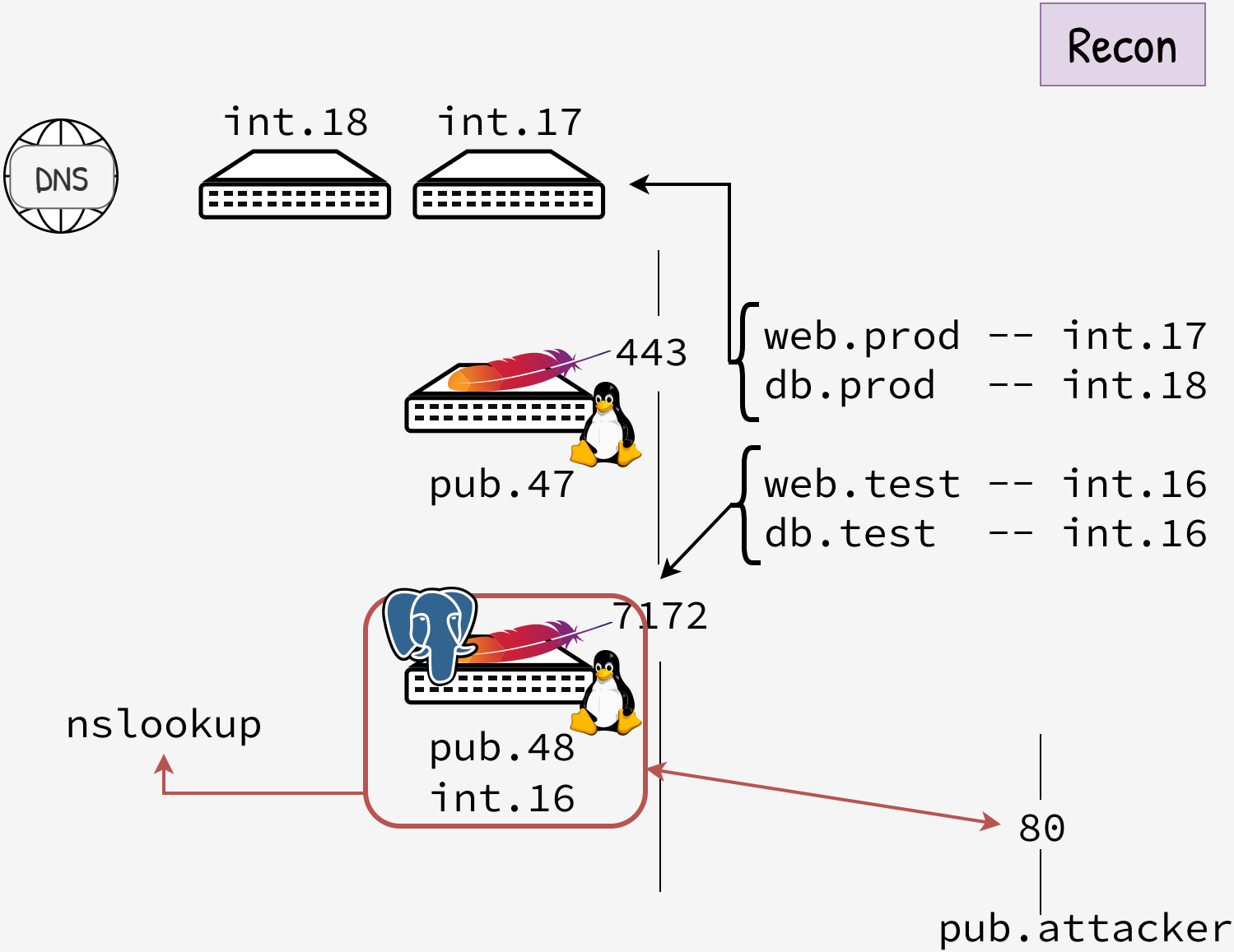


# What's next?

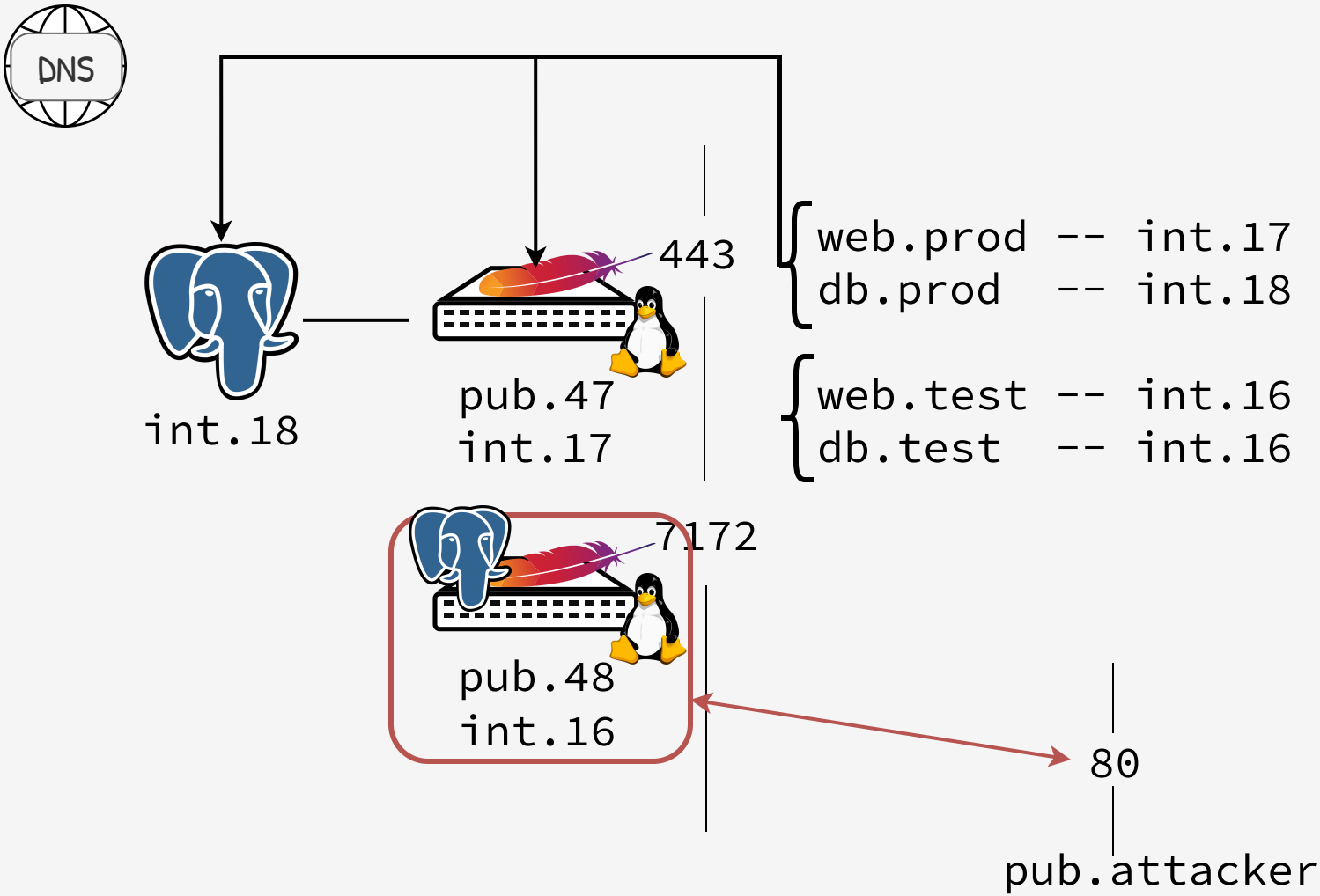


Recon

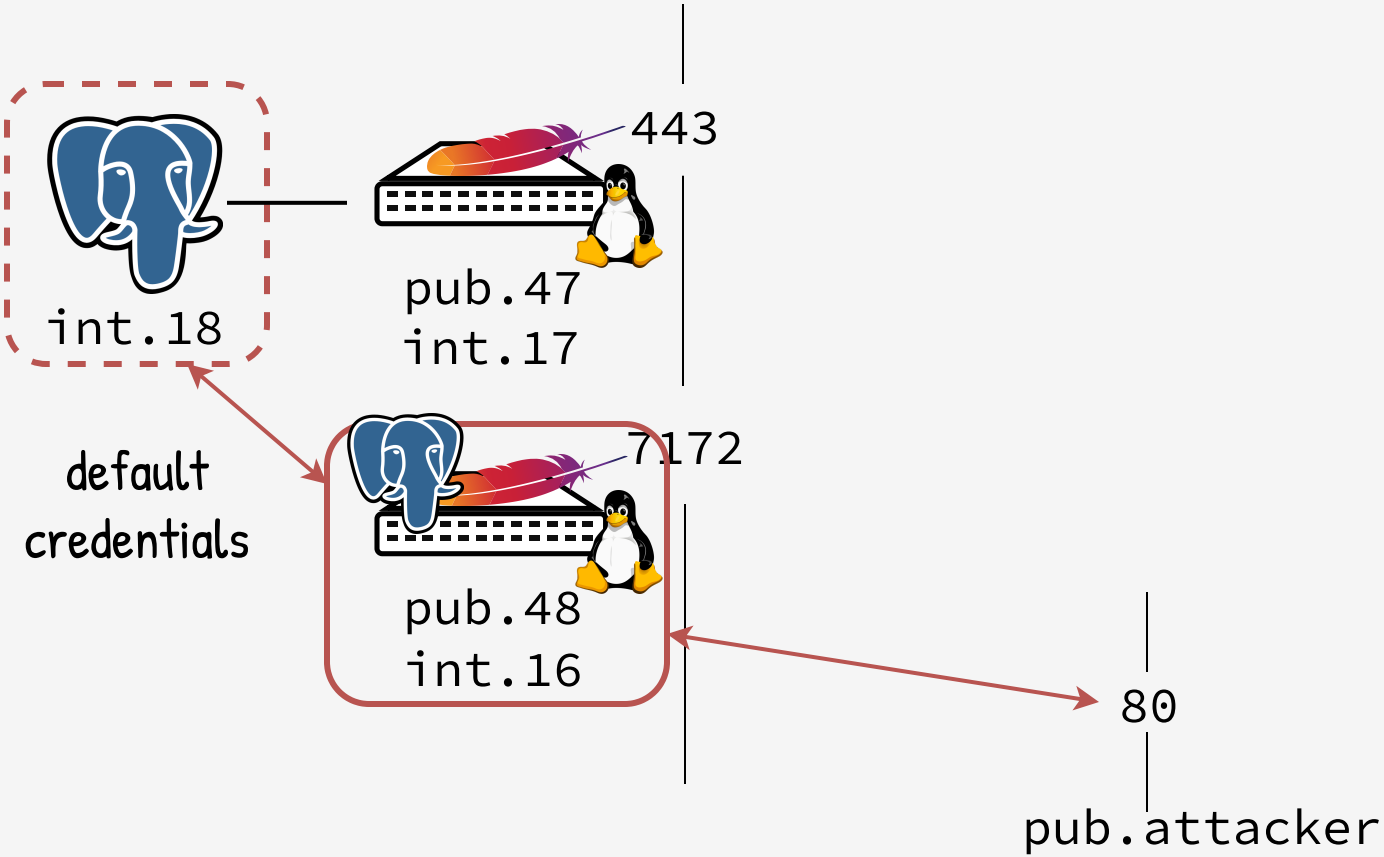

DNS
int.18
int.17
443
pub.47
7172
nmap int.0/24
pub.48
int.16
80
pub.attacker

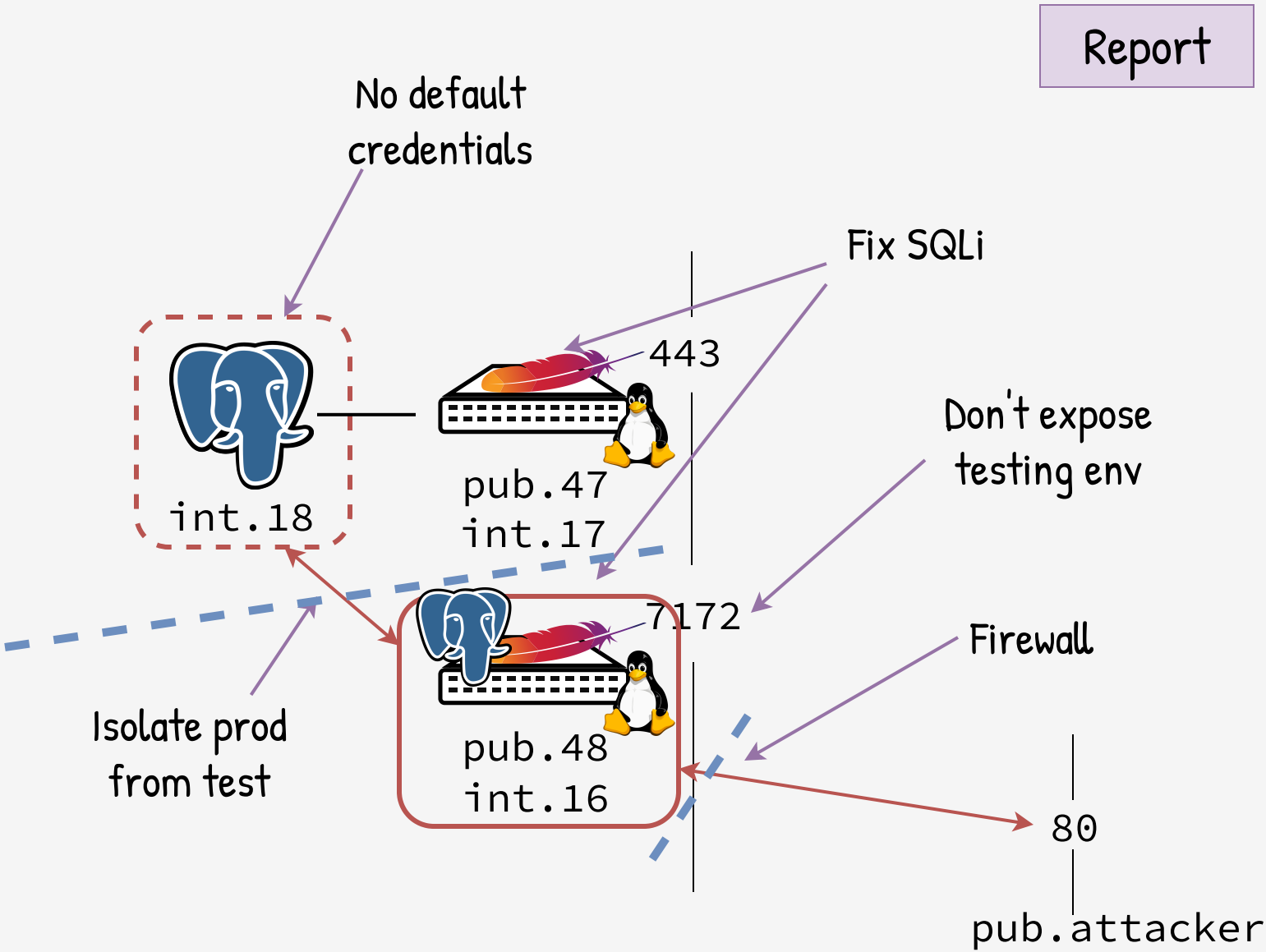

Recon
DNS
int.18
int.17
443
web.prod -- int.17
db.prod -- int.18
pub.47
web.test -- int.16
db.test -- int.16
7172
nslookup
pub.48
int.16
80
pub.attacker

Recon


DNS
443
web.prod -- int.17
db.prod -- int.18
int.18
pub.47
int.17
web.test -- int.16
db.test -- int.16
7172
pub.48
int.16
80
pub.attacker

Exploit


443
int.18
pub.47
int.17
7172
default
credentials
pub.48
int.16
80
pub.attacker


Report
No default credentials
Fix SQLi
443
Don't expose testing env
int.18
pub.47
int.17
7172
Firewall
Isolate prod from test
pub.48
int.16
80
pub.attacker